Guide Complet TP MQTT : Installation, Configuration et Sécurisation

Ce guide détaillé vous accompagnera à travers les étapes d'installation, de configuration et de sécurisation d'un broker MQTT sur Ubuntu, en suivant les instructions du TP fourni.

1. Préparation Système

Avant de commencer l'installation de Mosquitto, il est essentiel de préparer votre système Ubuntu en mettant à jour les paquets et en installant les dépendances nécessaires.

```
sudo apt update && sudo apt upgrade -y
sudo apt install -y curl gnupg2 ca-certificates software-properties-common
lsb-release docker.io docker-compose mosquitto-clients net-tools
sudo systemctl enable --now docker
lsb_release -a
sudo usermod -aG docker $USER # Redémarrez votre session ou votre machine
pour que les changements prennent effet.
```

2. Installation Mosquitto

Une fois le système préparé, nous allons installer le broker Mosquitto MQTT.

```
sudo add-apt-repository ppa:mosquitto-dev/mosquitto-ppa -y
sudo apt update && sudo apt install -y mosquitto mosquitto-clients
sudo systemctl enable --now mosquitto
ss -tulnp | grep 1883
```

Test Initial

Pour vérifier que Mosquitto fonctionne correctement, nous allons publier et souscrire à un topic de test.

```
mosquitto_sub -h localhost -t "test/topic" -v &
mosquitto_pub -h localhost -t "test/topic" -m "Hello MQTT"
```

3. Sécurisation

La sécurisation du broker MQTT est une étape cruciale. Nous allons configurer l'authentification par mot de passe, le chiffrement TLS et les listes de contrôle d'accès (ACL).

3.1 Authentification

Nous allons désactiver l'accès anonyme et configurer un fichier de mots de passe.

1. Éditez le fichier de configuration Mosquitto :

```
sudo nano /etc/mosquitto/mosquitto.conf
```

1. Ajoutez ou modifiez les lignes suivantes :

```
allow_anonymous false
password_file /etc/mosquitto/passwd
```

1. Créez un utilisateur et son mot de passe :

```
sudo mosquitto_passwd -c /etc/mosquitto/passwd user1
```

1. Redémarrez Mosquitto pour appliquer les changements :

```
sudo systemctl restart mosquitto
```

3.2 TLS (Transport Layer Security)

Le TLS permet de chiffrer les communications entre les clients et le broker. Nous allons générer un certificat auto-signé pour le test.

1. Générez les clés et le certificat :

```
openssl req -x509 -nodes -days 365 -newkey rsa:2048 -keyout
/etc/mosquitto/server.key -out /etc/mosquitto/server.crt -subj
"/CN=localhost"
```

1. Éditez le fichier de configuration Mosquitto (`sudo nano /etc/mosquitto/mosquitto.conf`) et ajoutez les lignes suivantes pour configurer le listener TLS :

```
listener 8883
cafile /etc/mosquitto/server.crt
certfile /etc/mosquitto/server.crt
keyfile /etc/mosquitto/server.key
```

1. Redémarrez Mosquitto :

```
sudo systemctl restart mosquitto
```

3.3 ACL (Access Control List)

Les ACLs permettent de définir des droits d'accès précis pour chaque utilisateur sur les topics. Créez un fichier ACL et configurez-le dans Mosquitto.

1. Créez le fichier ACL :

```
sudo nano /etc/mosquitto/aclfile
```

1. Ajoutez le contenu suivant (exemple du TP) :

```
user user1
topic readwrite test/#
topic read maison/temperature
```

1. Éditez le fichier de configuration Mosquitto (`sudo nano /etc/mosquitto/mosquitto.conf`) et ajoutez la ligne suivante :

```
acl_file /etc/mosquitto/aclfile
```

1. Redémarrez Mosquitto :

```
sudo systemctl restart mosquitto
```

4. Docker Compose

Le TP propose également de déployer Mosquitto via Docker Compose. Voici les étapes pour cela.

1. Créez un fichier `docker-compose.yml` :

```
nano docker-compose.yml
```

1. Ajoutez le contenu suivant :

```yaml
version: '3.8'
services:
  mqtt-broker:
    image: eclipse-mosquitto:2.0
    ports:
      - "1883:1883"
      - "9001:9001"
    volumes:
      - ./mosquitto.conf:/mosquitto/config/mosquitto.conf:ro
      - mosquitto_data:/mosquitto/data
volumes:
  mosquitto_data:
```

1. Créez un fichier `mosquitto.conf` pour Docker (vous pouvez copier celui que vous avez configuré précédemment ou en créer un nouveau avec les paramètres de sécurité) :

```bash
sudo cp /etc/mosquitto/mosquitto.conf ./mosquitto.conf
```

1. Démarrez les services Docker Compose :

```bash
docker-compose up -d
```

1. Affichez les logs pour vérifier le bon fonctionnement :

```bash
docker-compose logs
```

5. Sécurité IoT MQTT (Récapitulatif et Bonnes Pratiques)

Le TP met en évidence plusieurs aspects de la sécurité. Voici un récapitulatif des configurations de sécurité et des risques associés.

Fichier de configuration `/etc/mosquitto/mosquitto.conf` (Exemple de configuration sécurisée)

```
# Authentification par mot de passe
allow_anonymous false
password_file /etc/mosquitto/passwd

# Chiffrement TLS
listener 8883
cafile /etc/mosquitto/certs/ca.crt
certfile /etc/mosquitto/certs/server.crt
keyfile /etc/mosquitto/certs/server.key
require_certificate true

# ACL (contrôle d'accès par topic)
acl_file /etc/mosquitto/acl
```

Exemple de fichier ACL `/etc/mosquitto/acl`

```
# Utilisateur 'sensor_node_1' : lecture/écriture sur son topic uniquement
user sensor_node_1
topic readwrite home/sensor1/#

# Utilisateur 'dashboard' : lecture seule sur tous les topics home/
user dashboard
topic read home/#

# Interdire l'accès aux topics $SYS pour les clients non-admin
topic deny $SYS/#
```

Vulnérabilités, Risques et Mitigations

Vulnérabilité	Risque	Mitigation
Accès anonyme	Accès non autorisé	`allow_anonymous false`
MQTT clair	Interception (MITM)	TLS sur le port 8883
Topics permissifs	Injection de données, accès non voulu	ACLs (`user/topic` spécifiques)

6. Tests Sécurité

Après avoir configuré la sécurité, il est important de tester les différentes protections.

Test Anonyme (devrait échouer)

```
mosquitto_pub -h localhost -t test -m 'anon'
```

Test Authentification OK

```
mosquitto_pub -h localhost -u user1 -P password -t test -m 'auth'
```

Test TLS

```
mosquitto_pub -p 8883 --cafile /etc/mosquitto/server.crt -u user1 -P
password -t test -m 'tls'
```

7. Bonnes Pratiques & Diagnostic

Quelques bonnes pratiques et commandes utiles pour le diagnostic.

Firewall

Assurez-vous que le port TLS (8883) est ouvert dans votre pare-feu.

```
sudo ufw allow 8883
```

Logs

Pour surveiller les logs de Mosquitto en temps réel :

```
journalctl -u mosquitto -f
```

Autres Bonnes Pratiques

- Utiliser des dépôts officiels pour l'installation.
- Effectuer des sauvegardes régulières des certificats et clés.

8. Questions du TP

Voici les réponses aux questions posées dans le TP :

1. **Quels risques si MQTT non sécurisé ?**
    - **Accès non autorisé :** N'importe qui peut publier ou souscrire à des topics, menant à la fuite d'informations sensibles ou à l'injection de commandes malveillantes.
    - **Interception de données (Man-in-the-Middle) :** Les données transmises en clair peuvent être lues et modifiées par un attaquant.
    - **Déni de service (DoS) :** Un attaquant peut inonder le broker de messages, le rendant indisponible pour les clients légitimes.
    - **Usurpation d'identité :** Un attaquant peut se faire passer pour un client ou un broker légitime.
2. **Différence TLS/mTLS ?**
    - **TLS (Transport Layer Security) :** Fournit une authentification unilatérale où le client vérifie l'identité du serveur (broker MQTT) via son certificat. Le chiffrement des communications est également assuré.
    - **mTLS (Mutual Transport Layer Security) :** Fournit une authentification mutuelle, où le client vérifie l'identité du serveur, et le serveur vérifie également l'identité du client via son certificat. Cela offre un niveau de sécurité plus élevé car les deux parties doivent prouver leur identité.
3. **Pourquoi ACL ?** Les ACL (Access Control Lists) sont essentielles pour implémenter le principe du moindre privilège dans un environnement MQTT.

Elles permettent de :

- **Contrôler finement les accès :** Définir quels utilisateurs peuvent publier ou souscrire à quels topics.
- **Isoler les communications :** Empêcher un utilisateur d'accéder à des topics qui ne le concernent pas.
- **Améliorer la sécurité :** Réduire la surface d'attaque en limitant les actions possibles pour chaque client, même si un compte utilisateur est compromis.

Livrable

Ce document contient le code généré et les explications nécessaires pour le TP. Pour le rapport final, il est recommandé d'inclure des captures d'écran des différentes étapes et des tests.